

CYBER SECURITY

PHISHING PROTECTION

HOW TO START A PROGRAM

VERSION: 1.5
DATE: 26/06/2019
AUTHOR: SYLVAIN MARTINEZ
REFERENCE: ESC17-MUSCL
CLASSIFICATION: PUBLIC



CONTENTS

CONTEXT

- Presentation goal;
- Phishing Statistics;
- Incident cost;
- Phishing protection benefits;
- Phishing definition;
- Spear Phishing definition;
- Phishing email – From the outside;
- Phishing email – From the inside;
- Phishing Website – From the outside;
- Phishing Website – From the inside;

PROGRAM

- Phishing protection program overview;

AWARENESS

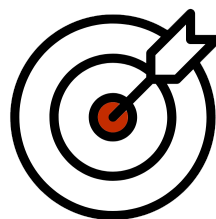
- Training overview;
- Training – Awareness campaign;
- Training – Guidelines;
- Testing overview;
- Testing – URLs;
- Testing – Attachments;
- Testing – Phishing simulation planning;

DEFENCES

- Detection overview;
- Detecting – Manual detection;
- Detecting – Automated detection;
- Protecting overview;
- Protecting – Warn;
- Protecting – Block;

CONCLUSION

- Key Take Away;
- Get Started;
- Extra Resources.



TO LEARN ABOUT PHISHING PROTECTION SOLUTIONS

1

**LEARN ABOUT DIFFERENT TYPE
OF PHISHING ATTACKS**

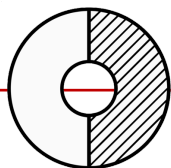
2

**LEARN ABOUT DIFFERENT TYPE
OF PHISHING PROTECTIONS**

3

**LEARN HOW TO START AN
ANTI-PHISHING PROGRAM**

PHISHING STATISTICS



ALL EMAILS

45%

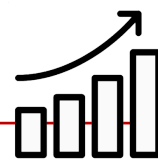
ARE SPAM



SPAM

14.5 BILLION

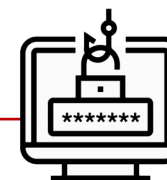
EVERY DAY



GROWTH

65%

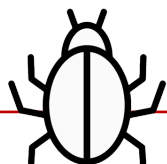
PHISHING IN 2018



PHISHING SITES

1.5 MILLION

NEW EVERY MONTH



MALWARE

92%

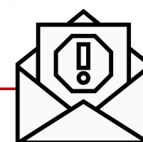
EMAIL DELIVERED



PHISHING EMAIL

16

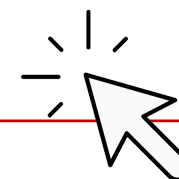
MONTHLY PER USER



PHISHING OPEN

30%

BY TARGETED USERS



PHISHING CLICK

12%

BY TARGETED USERS

INCIDENT COST

ELYSIUMSECURITY INVESTIGATIONS

MAURITIUS

JANUARY 2018 – JUNE 2019

80% FINANCIAL FRAUD

20% RANSOMWARE

100% PHISHING

JAN 2018 \$0.5M

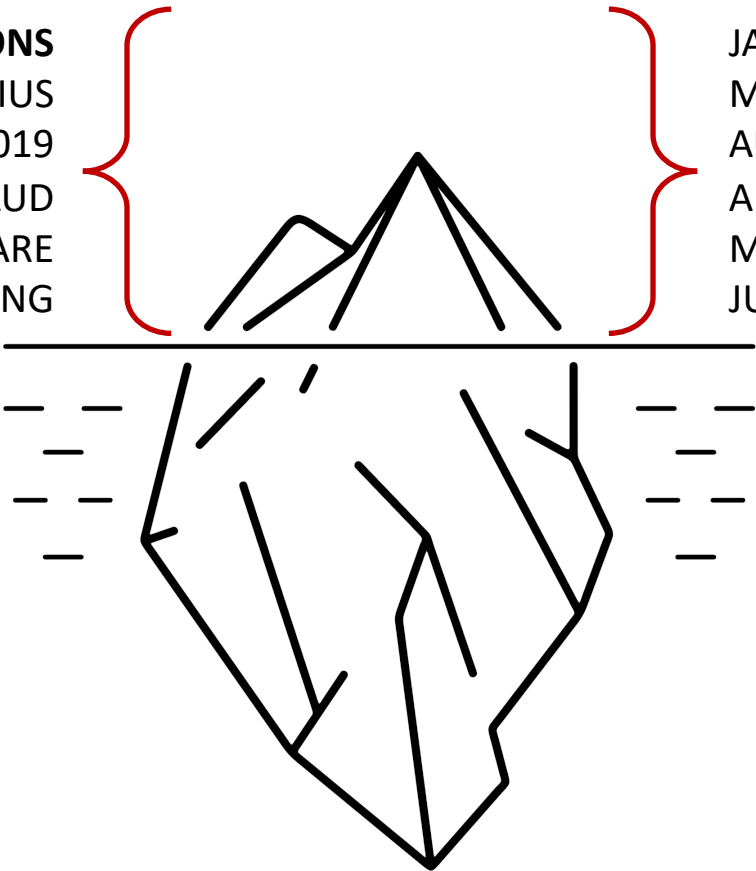
MAY 2018 \$1M

AUG 2018 \$2M

APR 2019 \$0.5M

MAY 2019 \$1M

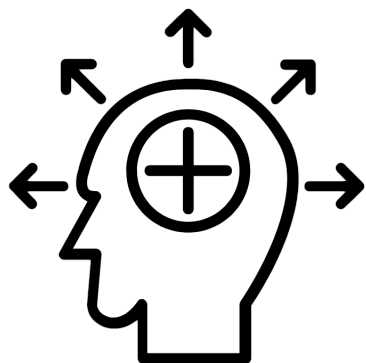
JUNE 2019 \$0.5M



WORLDWIDE

\$3.86M AVERAGE COST PER DATA BREACH
\$1.6M AVERAGE COST PER PHISHING ATTACK
95% DATA BREACHES FROM PHISHING ATTACKS
197 DAYS AVERAGE DETECTION TIME

PHISHING PROTECTION BENEFITS



IMPROVED AWARENESS

KNOW PHISHING RISKS

BETTER PHISHING DETECTION

FOLLOW BEST PRACTISE

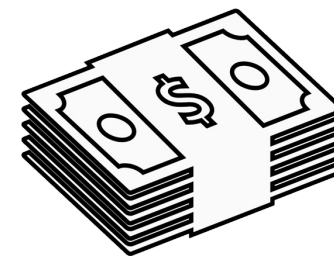


IMPROVED SECURITY

STAFF BETTER PROTECTED

BETTER EMAIL PROTECTION

INCREASED ATTACK VISIBILITY



REDUCED PHISHING COST

LOWER PHISHING SUCCESS RATE

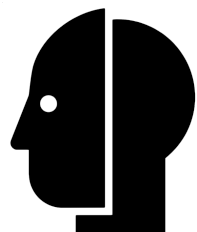
LIMITED PHISHING IMPACT COST

REDUCED/AVOID FINES

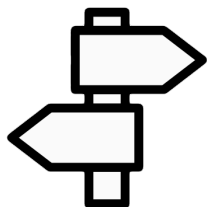
PHISHING DEFINITION



PHISHING IS A TYPE OF SOCIAL ENGINEERING ATTACK USED TO STEAL SENSITIVE INFORMATION SUCH AS PASSWORDS OR FINANCIAL DETAILS



ATTACKERS PRETEND TO BE A TRUSTED ENTITY TO PUSH VICTIMS INTO OPENING FRAUDULENT LINKS OR ATTACHMENTS.

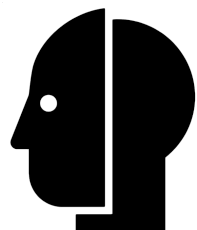


THIS IS A GENERIC ATTACK USING COMMON MESSAGES THAT MAY BE RELEVANT TO THE VICTIMS CONTRIBUTING TO THEIR FALSE SENSE OF TRUST

SPEAR PHISHING DEFINITION



SPEAR PHISHING IS AN ADVANCED TYPE OF SOCIAL ENGINEERING ATTACK USED TO STEAL SENSITIVE INFORMATION SUCH AS PASSWORDS OR FINANCIAL DETAILS

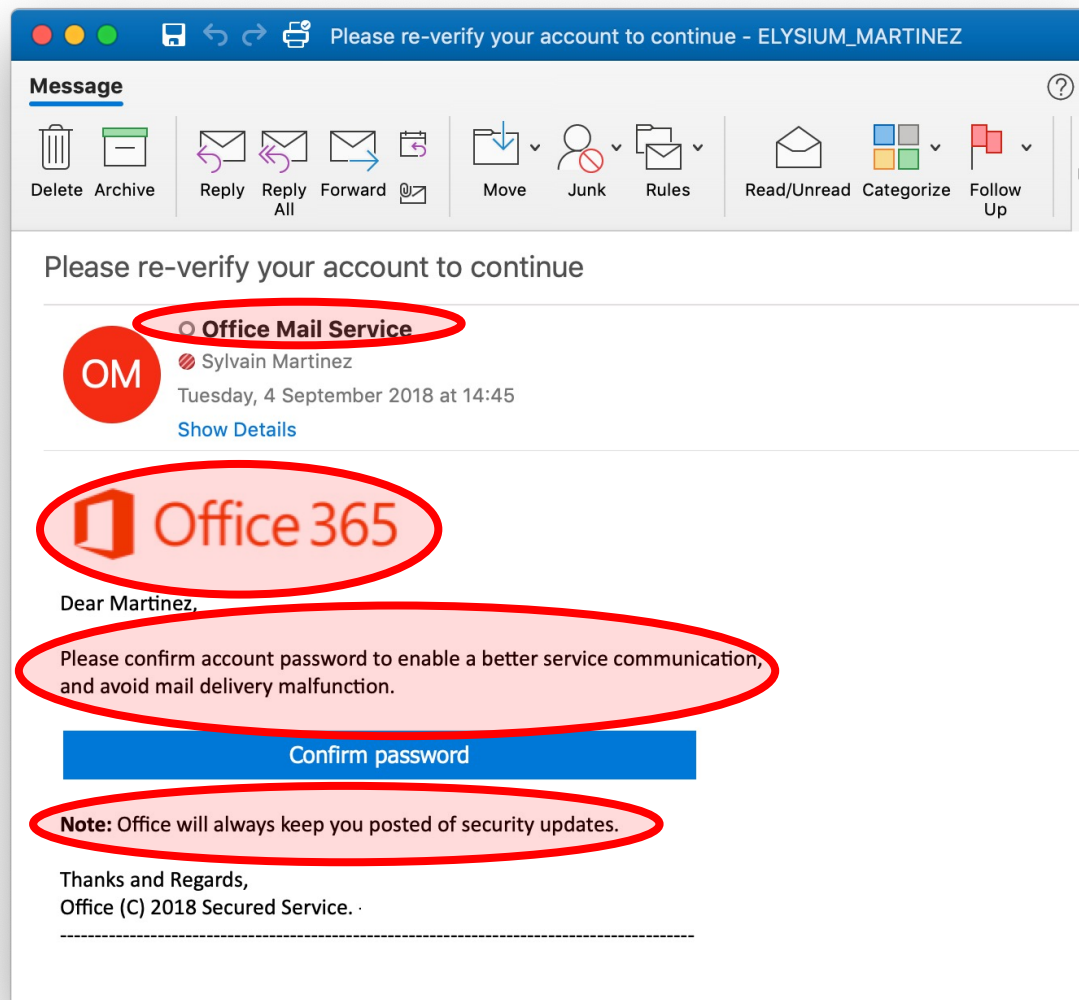


ATTACKERS PRETEND TO BE A TRUSTED ENTITY TO PUSH VICTIMS INTO OPENING FRAUDULENT LINKS OR ATTACHMENTS



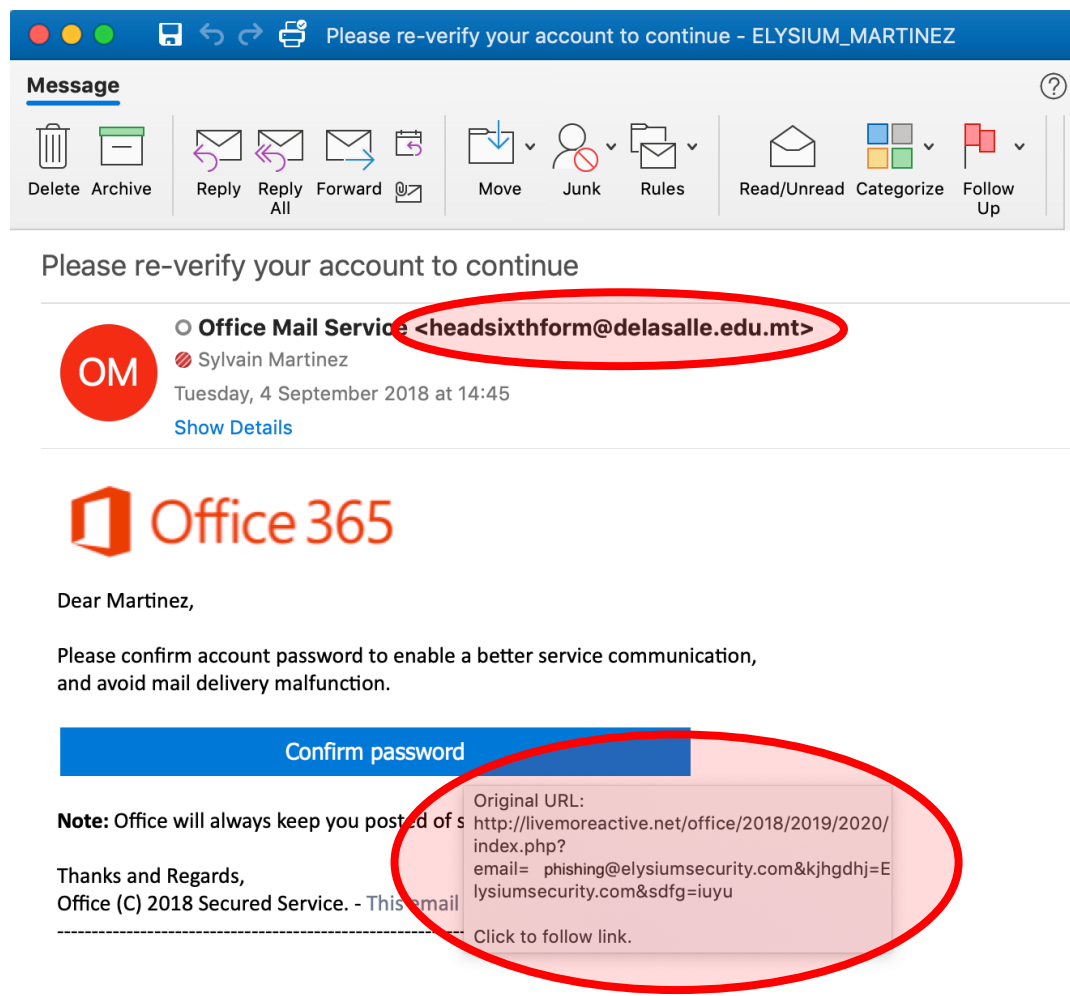
THIS IS A VERY FOCUSED ATTACK USING SPECIFIC MESSAGES WITH PERSONAL AND RELEVANT INFORMATION TO THE VICTIMS INCREASING THEIR FALSE SENSE OF TRUST

PHISHING EMAIL - FROM THE OUTSIDE



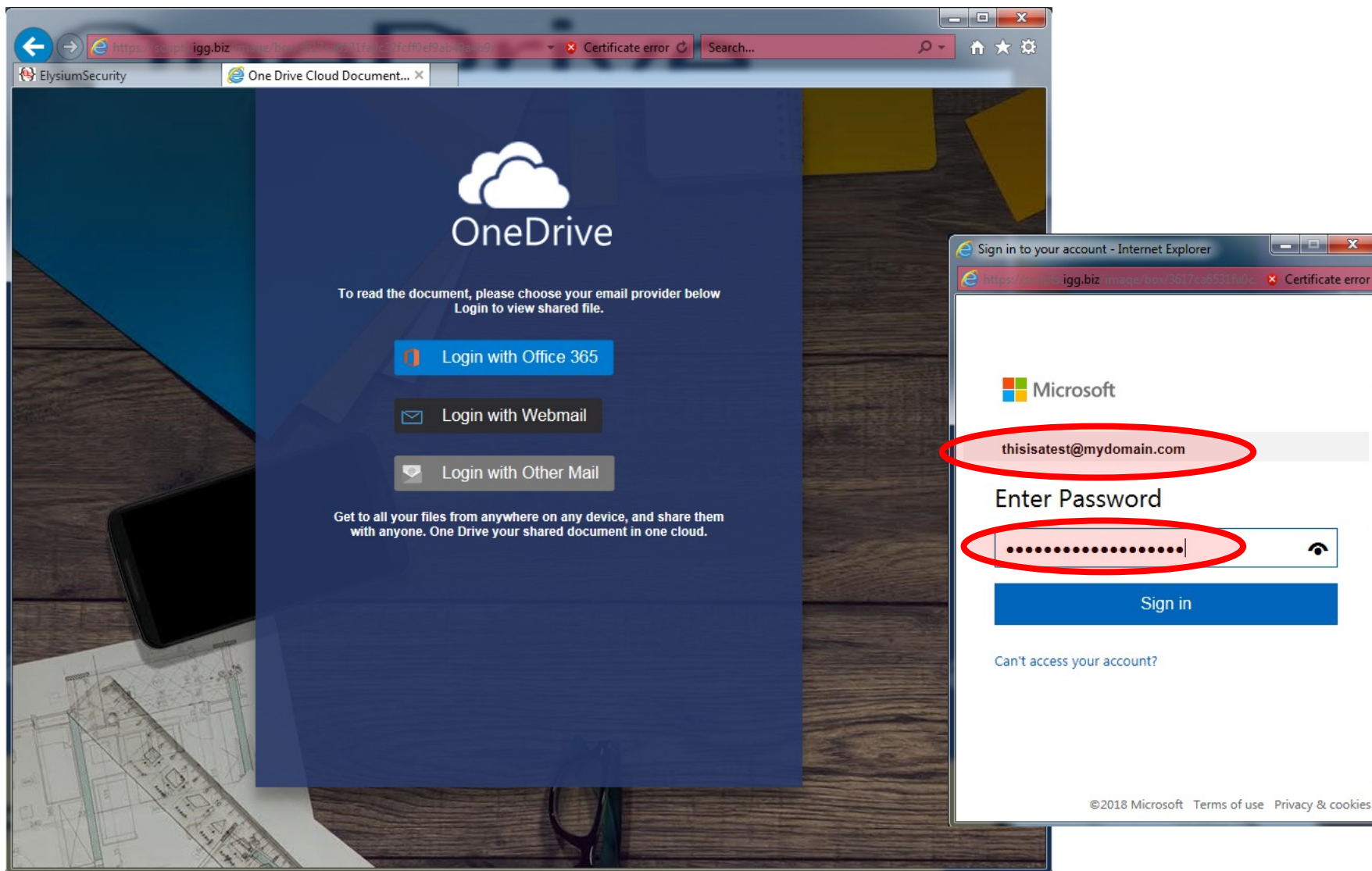
LOOKS AND
SOUNDS
LEGITIMATE

PHISHING EMAIL - FROM THE INSIDE



**WARNING
SIGNS IF YOU
KNOW WHERE
TO LOOK!**

PHISHING WEBSITE - FROM THE OUTSIDE



PHISHING WEBSITE- FROM THE INSIDE

```
POST /image/box/3617ca6531fa0c32fcff0ef9ab49a4b9/office/mail.php HTTP/1.1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Referer: https://scripts.igg.biz/image/box/3617ca6531fa0c32fcff0ef9ab49a4b9/office/sign-to-officel.php
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate
Host: scripts.igg.biz
Content-Length: 77
Content-Type: 1
Connection: close
Cache-Control: no-cache

username=thisisatest@mydomain.com&password=thisisnotmypassword&signin=Sign+in
```

**YOUR CREDENTIALS ARE INTERCEPTED AND
SENT... TO THE WRONG PLACE / PERSON!**

PHISHING PROTECTION PROGRAM OVERVIEW

CAMPAIGN #1

PHISHING

ALL STAFF
GENERIC

MOST COMMON
INEXPENSIVE

SIMPLE ATTACK
AUTOMATED

CAMPAIGN #2

SPEAR PHISHING

KEY STAFF
TARGET TAILORED

LEAST COMMON
EXPENSIVE

COMPLEX ATTACK
MANUAL

TRAINING

AWARENESS
CAMPAIGN

GUIDELINES

PROTECTING

WARN

BLOCK

{elysiumsecurity} PHISHING PROTECTION PROGRAM

DETECTING

MANUAL

AUTOMATED

TESTING

CLICK URL

OPEN
ATTACHMENT

TRAINING OVERVIEW

TRAINING

AWARENESS
CAMPAIGN

GUIDELINES

1

SOME PHISHING WILL ALWAYS GO THROUGH CYBER DEFENCES

2

USER AWARENESS IS YOUR FIRST DEFENCE AGAINST PHISHING

3

TRAIN YOUR USERS TO UNDERSTAND PHISHING RISKS AND LOOKS

TRAINING - AWARENESS CAMPAIGN

1

RELEVANT TO YOUR
CORPORATE RISK
PROFILE

2

COORDINATED
WITH CORPORATE
COMMUNICATION

3

LINKED TO WIDER
CYBER SECURITY
AWARENESS

4

MIX OF IN PERSON
AND DIGITAL
DELIVERY

5

USE OF RELATABLE
EXAMPLES

6

REGULAR AND
REPEATED

7

SET AND REVIEW
KEY PERFORMANCE
INDICATORS

8

RESULTS FEEDBACK
CAN BE A TRAINING
TOOL

9

POSTER

10

CHEAT SHEET

TRAINING - GUIDELINES

DO

1

DO THINK BEFORE
YOU CLICK

2

DO CHECK EMAIL
PROVENANCE

3

DO CHECK EMAIL
CONTEXT

4

DO BE CAREFUL OF
DISAPPEARING
EMAILS

5

DO REPORT
SUSPICIOUS EMAILS

DO NOT

7

DO NOT IGNORE
SECURITY
WARNINGS

8

DO NOT OPEN
UNEXPECTED
ATTACHMENT

9

DO NOT CLICK
UNEXPECTED URL

10

DO NOT ENTER
PASSWORDS FROM
URL IN EMAILS

6

DO NOT USE WORK
EMAIL FOR
PERSONAL PURPOSE

TESTING OVERVIEW

TESTING

CLICK URL

OPEN
ATTACHMENT

1

VALIDATE AWARENESS CAMPAIGN EFFICIENCY

2

IDENTIFY MOST VULNERABLE USERS

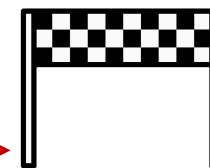
3

USE PHISHING SIMULATION TOOLS

TESTING - URLS



START



FINISH

1 GENERIC EMAIL CONTEXT

6

SPECIFIC EMAIL CONTEXT

2 OBVIOUS SUSPICIOUS URL

7

DIFFICULT TO SPOT URL

3 ONLY SIMULATE CLICK BAIT

8

SIMULATE PORTAL CREDENTIAL STEALTH

4 REDIRECT TO GENERIC MESSAGE

9

REDIRECT TO AWARENESS CAMPAIGN

5 RECORD VICTIM DETAILS

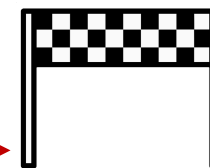
10

RECORD VICTIM DETAILS AND STATISTICS

TESTING - ATTACHMENTS



START



FINISH

1 GENERIC EMAIL CONTEXT

6 SPECIFIC EMAIL CONTEXT

2 OBVIOUS SUSPICIOUS ATTACHMENT

7 DIFFICULT TO SPOT ATTACHMENT

3 ONLY SIMULATE CLICK BAIT

8 SIMULATE MALWARE INSTALLATION

4 REDIRECT TO GENERIC MESSAGE

9 REDIRECT TO AWARENESS CAMPAIGN

5 RECORD VICTIM DETAILS

10 RECORD VICTIM DETAILS AND STATISTICS

TESTING – PHISHING SIMULATION PLANNING

1

LIST TARGETED
USERS (ALL / FEW)

2

EMAIL SCOPE (SAME
VERSION FOR ALL?)

3

CLEAR GOALS AND
TIMELINE

4

VICTIM MESSAGE
READY

5

INFORM STAFF
PRIOR STARTING

6

ESTABLISH BASELINE
(GENERIC ATTACK)

7

ANALYSE RESULTS
AND ADAPT

8

REFINE TEMPLATES

9

BEWARE OF
GDPR/DPA WHEN
USING 3rd PARTY

10

SPEAR PHISHING
TEST WHEN
MATURE ENOUGH

DETECTING OVERVIEW

DETECTING

MANUAL

AUTOMATED

1

MONITOR EMAIL SECURITY

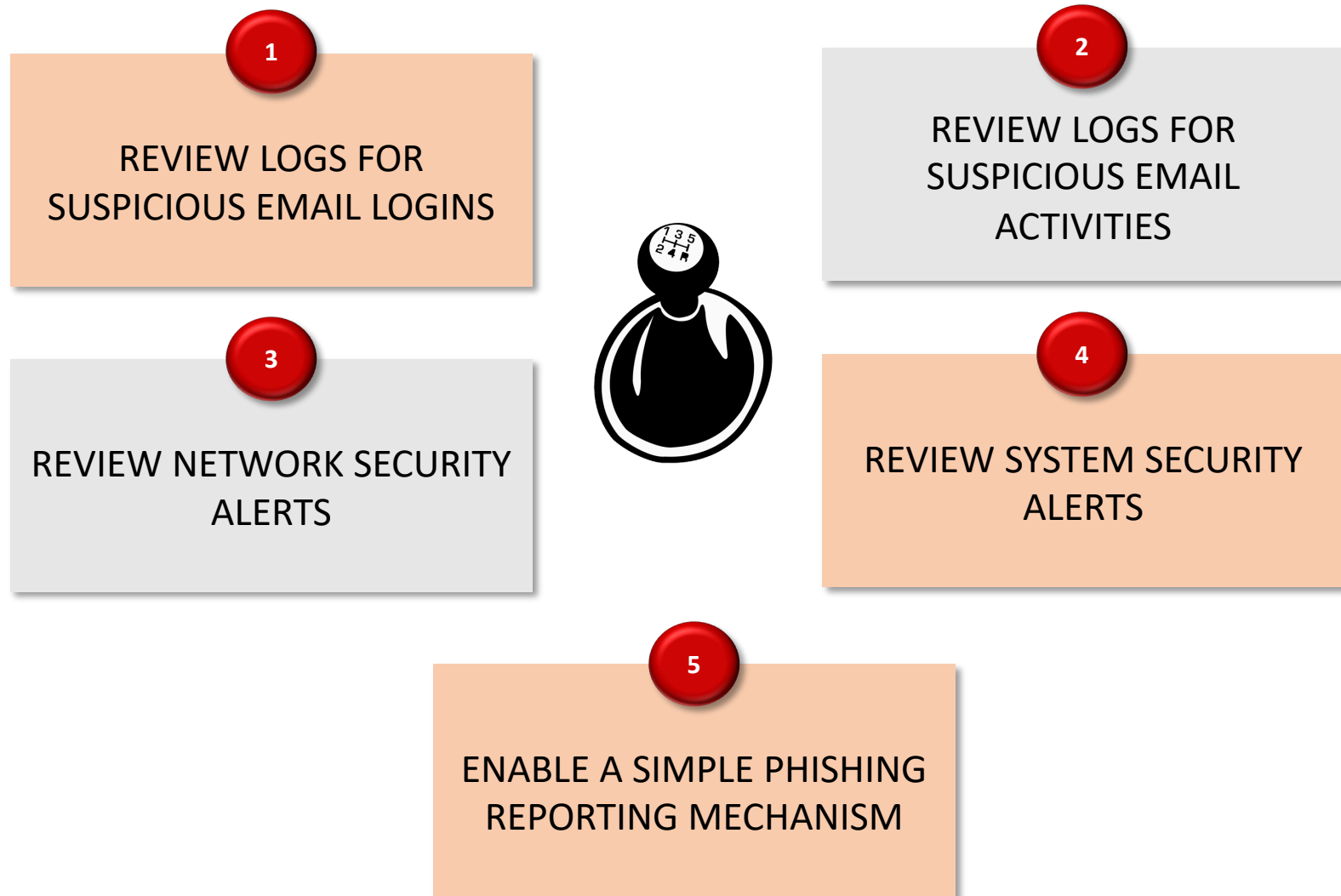
2

ENABLE AND ENHANCE PHISHING VISIBILITY

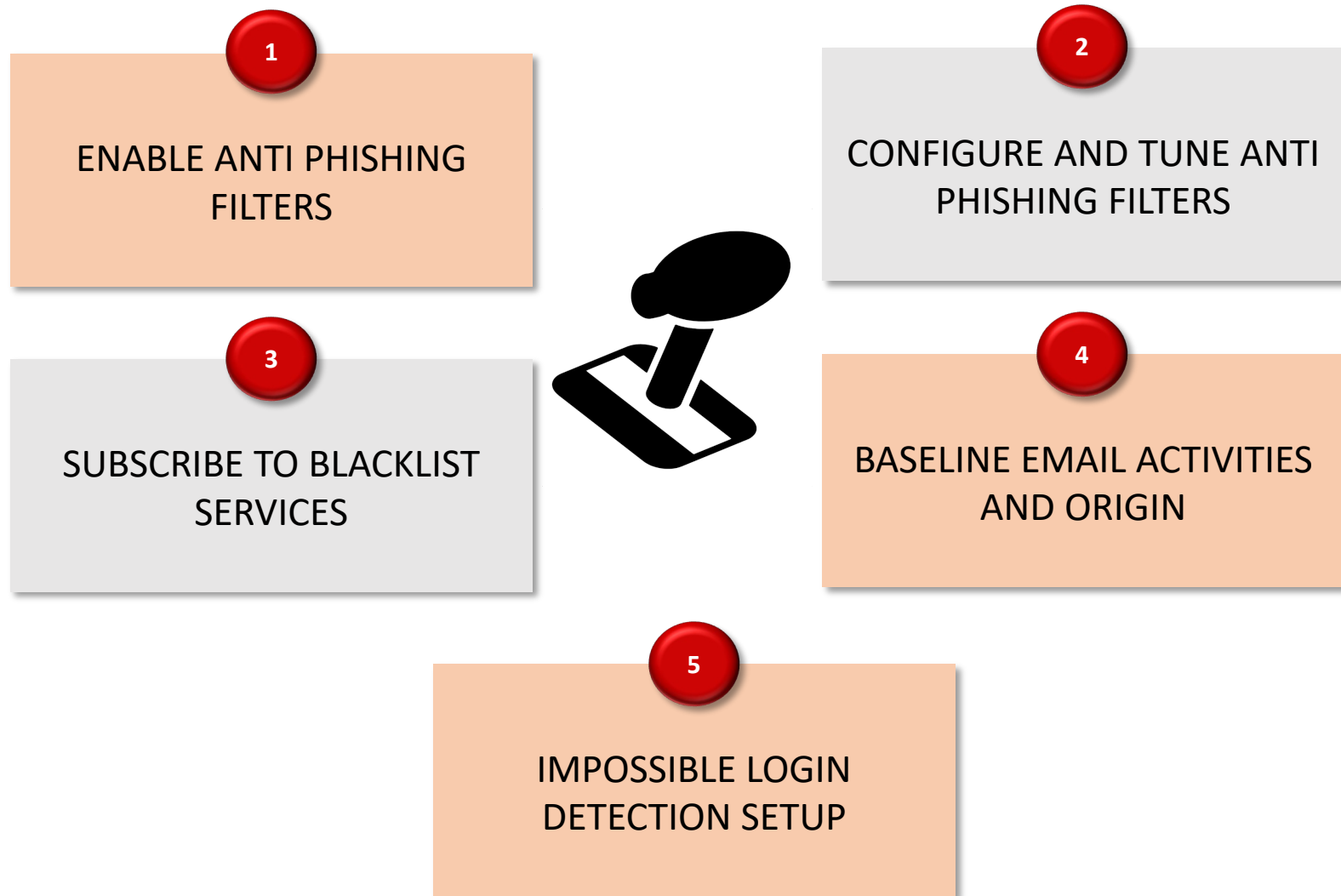
3

FACILITATE PHISHING INCIDENT RESPONSE

DETECTING - MANUAL DETECTION



DETECTING - AUTOMATED DETECTION



PROTECTING OVERVIEW

PROTECTING

WARN

BLOCK

1

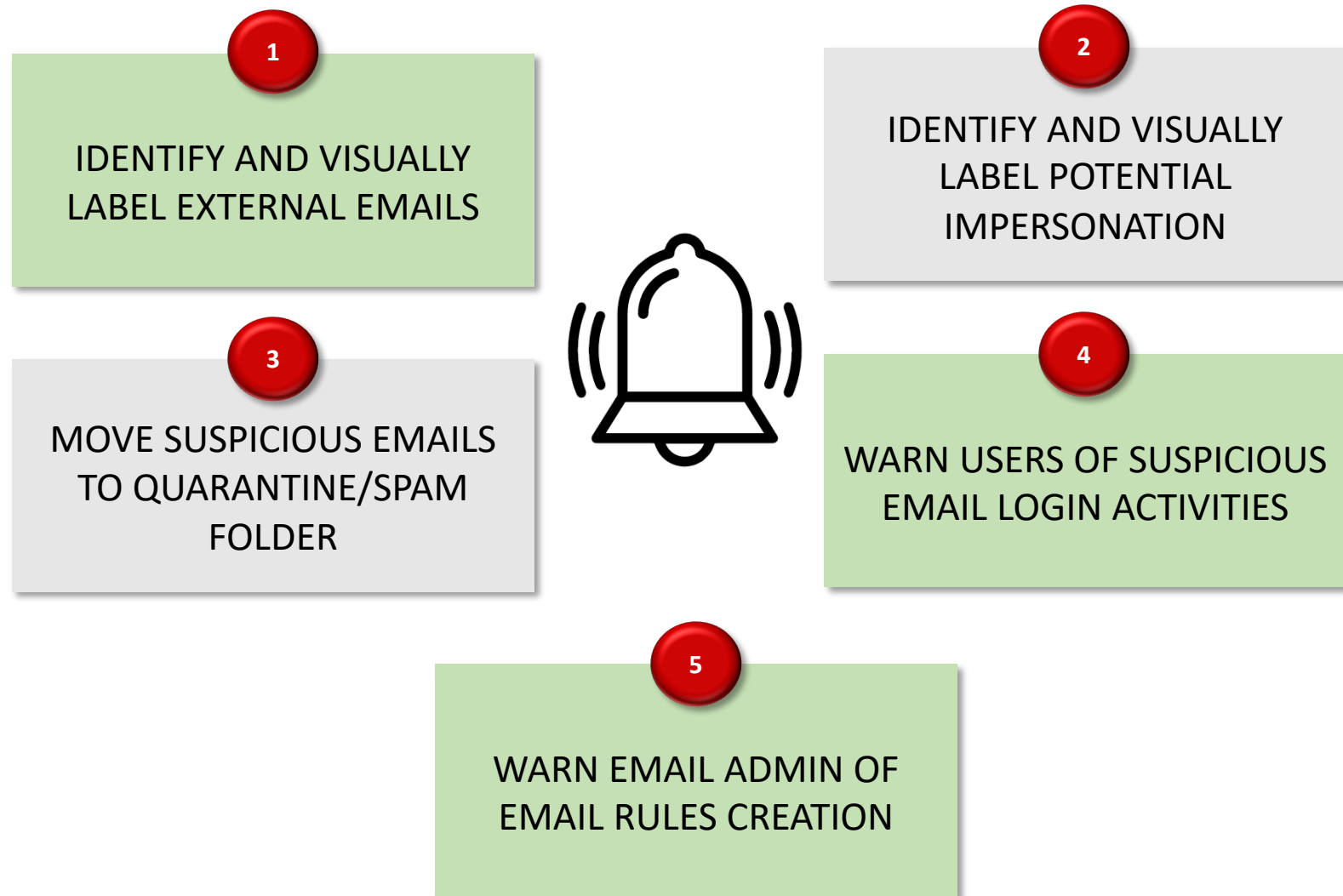
REDUCE PHISHING RELATED INCIDENT

2

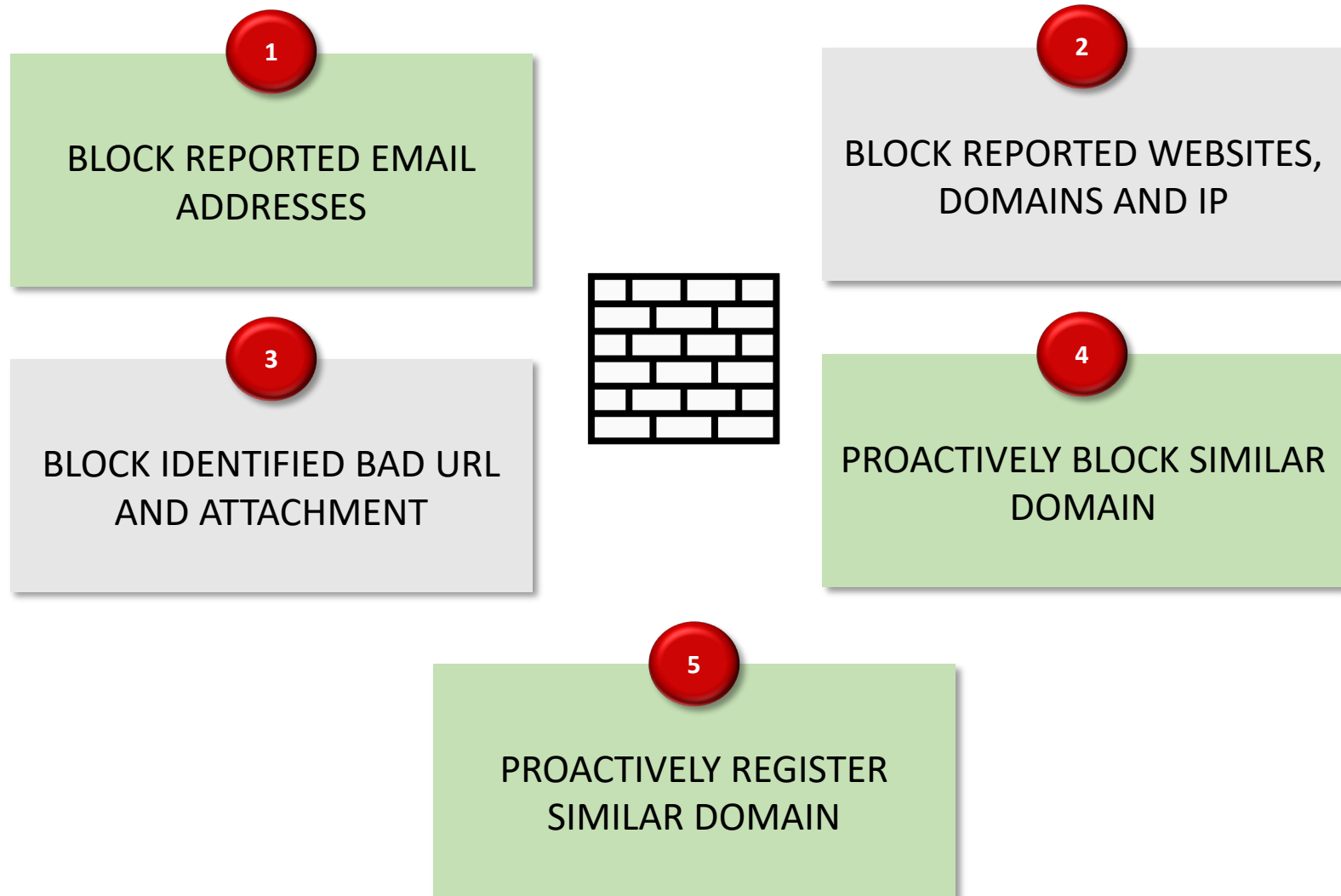
ALERT USER OF POTENTIAL PHISHING ATTACKS

3

BLOCK IDENTIFIED PHISHING ATTACKS



PROTECTING - BLOCK



KEY TAKE AWAY

1

PHISHING IS THE MOST COMMON ATTACK VECTOR TODAY

2

BE AWARE OF PHISHING VERSUS SPEAR PHISHING

3

AWARENESS IS KEY

4

IMPORTANCE OF PHISHING PROTECTION

5

IMPORTANCE OF EMAIL ACCESS PROTECTION

1

STAY INFORMED OF PHISHING CAMPAIGNS

2

REMIND STAFF OF PHISHING RISKS

3

USE SECURE EMAIL PROVIDER

4

ENFORCE EMAIL PROTECTIONS

5

**DEFINE AND IMPLEMENT A PHISHING
PROTECTION PROGRAM**

EXTRA RESOURCES

TRAINING



AVERAGE COST

\$10 / YEAR / USER / NO CUSTOMISATION

MIMECAST

ALSO OFFERS WIDER CYBER SECURITY TRAINING

<https://www.mimecast.com/content/phishing-awareness>

TREND MICRO

ALSO OFFERS WIDER CYBER SECURITY TRAINING

<https://phishinsight.trendmicro.com/en/training>

CYBERAWARE

FREE RESOURCES

<https://free.thesecurityawarenesscompany.com/downloads/category/videos/>

SANS

CAN BE EXPANSIVE BUT ALSO HAS FREE RESOURCES

<https://www.sans.org/security-awareness-training>

ESET

CLAIMS TO BE FREE BUT MAY HAVE SOME HIDDEN COST

<https://www.eset.com/us/cybertraining/>

GARTNER

COMPARE DIFFERENT OFFERINGS

<https://www.gartner.com/reviews/market/security-awareness-computer-based-training/>



SIMULATOR

AVERAGE COST

FREE - \$10 / YEAR / USER

COFENSE

BOUGHT MARKET LEADER CALLED PHISHME.COM

<https://cofense.com/simulator-small-business-edition>

TREND MICRO

FREE AND PAID SUBSCRIPTION

<https://cofense.com/simulator-small-business-edition>

PHISHING READINESS

THIS IS A PRODUCT BY SYMANTEC

<https://www.symantec.com/products/phishing-readiness>

KNOWBE4

THIS IS A COMPANY BY KEVIN MITNICK

<https://www.knowbe4.com/>

MICROSOFT

ATTACK SIMULATOR – ATP PLAN 2

<https://docs.microsoft.com/en-us/office365/securitycompliance/attack-simulator>

GOPHISH

OPENSOURCE AND PROFESSIONAL VERSIONS

<https://getgophish.com/>

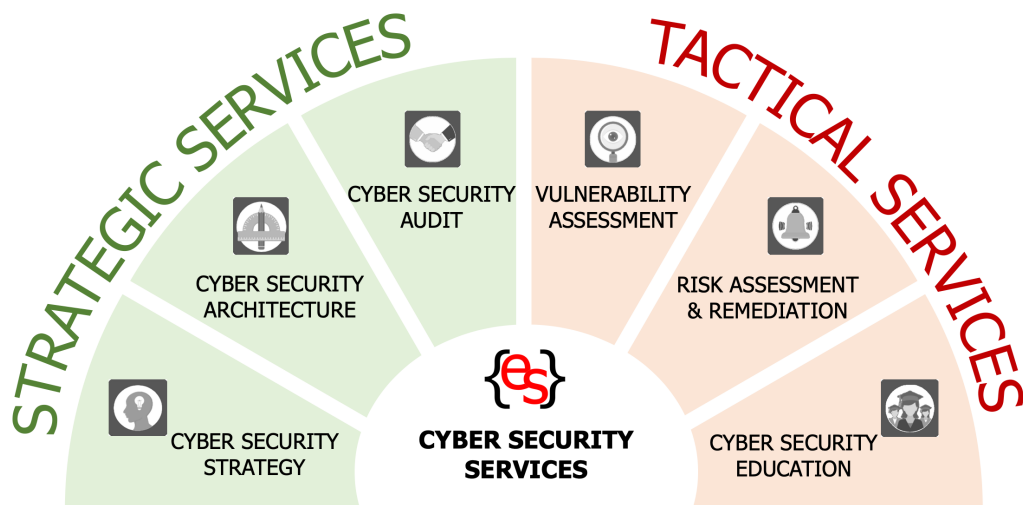
ABOUT ELYSIUMSECURITY LTD.

ELYSIUMSECURITY PROVIDES A PORTFOLIO OF **STRATEGIC** AND **TACTICAL SERVICES** TO HELP COMPANIES **PROTECT** AND **RESPOND** AGAINST **CYBER SECURITY THREATS**. WE DIFFERENTIATE OURSELVES BY OFFERING **DISCREET, TAILORED** AND **SPECIALIZED** ENGAGEMENTS.

ELYSIUMSECURITY OPERATES IN **MAURITIUS** AND IN **EUROPE**, A **BOUTIQUE STYLE** APPROACH MEANS WE CAN **EASILY ADAPT** TO YOUR BUSINESS OPERATIONAL MODEL AND REQUIREMENTS TO PROVIDE A **PERSONALIZED SERVICE** THAT FITS YOUR WORKING ENVIRONMENT.

ELYSIUMSECURITY PROVIDES **HIGH LEVEL EXPERTISE** GATHERED THROUGH YEARS OF **BEST PRACTICES EXPERIENCE** IN LARGE INTERNATIONAL COMPANIES ALLOWING US TO PROVIDE ADVICE BEST SUITED TO YOUR **BUSINESS OPERATIONAL MODEL** AND **PRIORITIES**.

ELYSIUMSECURITY PROVIDES **PRACTICAL EXPERTISE** TO **IDENTIFY VULNERABILITIES**, ASSESS THEIR **RISKS** AND **IMPACT**, **REMEDIATE** THOSE RISKS, **PREPARE** AND **RESPOND** TO INCIDENTS AS WELL AS RAISE **SECURITY AWARENESS** THROUGH AN ORGANIZATION.



© 2015-2019 ELYSIUMSECURITY LTD
ALL RIGHTS RESERVED

[HTTPS://WWW.ELYSIUMSECURITY.COM](https://www.elysiumsecurity.com)
CONSULTING@ELYSIUMSECURITY.COM